

SIMATS ENGINEERING

ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1407

1. Nmap Scan Report Analysis

Scenario

A security analyst scanned 192.168.1.10 using Nmap. The scan identified:

- HTTP – Port 80
- SSH – Port 22
- MySQL – Port 3306
- Operating System and Service Versions

COMMAND: nmap -A 192.168.1.10

EXPLANATION:

nmap – Network Mapper tool used to discover hosts and services on a network.

-A – Enables advanced scan features:

- Operating System Detection
- Service Version Detection
- Default NSE (Nmap Scripting Engine) scripts
- Traceroute

192.168.1.10 – Target IP address to be scanned.

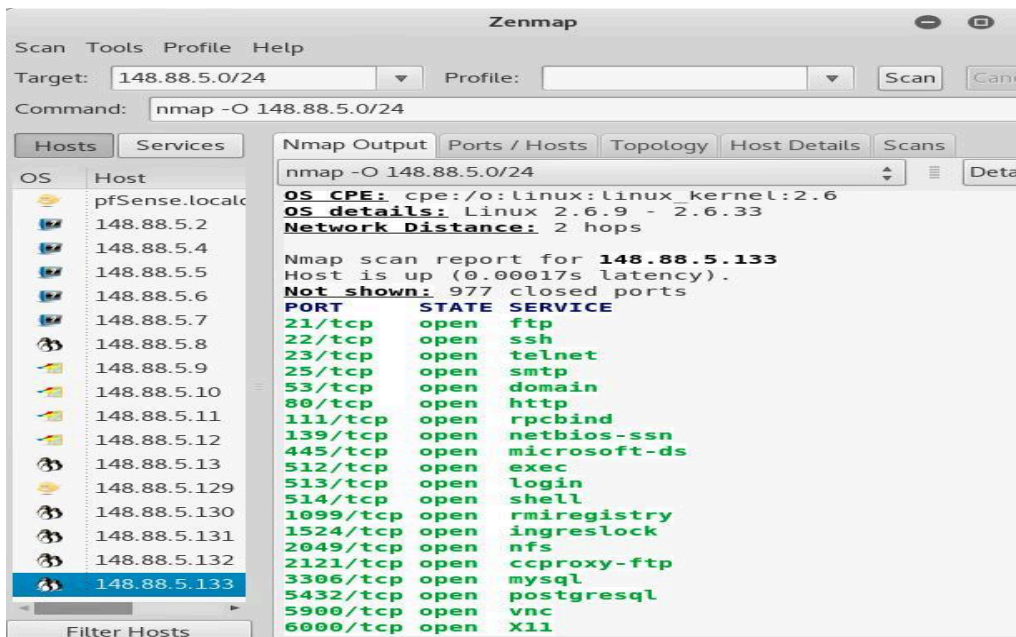
```

root@kali:~# nmap 192.168.33.10

Starting Nmap 7.60 ( https://nmap.org ) at 2017-10-03 08:25 EDT
Nmap scan report for 192.168.33.10
Host is up (1.1s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
443/tcp   open  https
3306/tcp   open  mysql

Nmap done: 1 IP address (1 host up) scanned in 3.63 seconds
root@kali:~#

```



Analysis of Open Ports

For HTTP

- Use **HTTPS** instead of HTTP.
- Update web applications.

- Deploy a Web Application Firewall (WAF).

For SSH

- Disable root login.
- Use strong passwords.
- Enable Multi-Factor Authentication (MFA).
- Allow SSH access only from trusted IP addresses.

For MySQL

- Restrict remote database access.
- Change default credentials.
- Use strong passwords.
- Keep MySQL updated.

General Recommendations

- Patch operating systems regularly.
- Close unnecessary ports.
- Enable firewalls.
- Monitor logs.
- Perform regular vulnerability scans.

Conclusion

The Nmap scan reveals exposed services that may become entry points for attackers. Proper patching, access control, encryption, and continuous monitoring significantly reduce the risk of compromise.

2. GoPhish Report Analysis

Scenario

Results:

- 40% clicked phishing links.

- 20% entered login credentials.
- Several employees downloaded malicious attachments.

COMMAND: cd ~/gophish
sudo ./gophish

EXPLANATION :

- cd** – Changes the current working directory.
- ~/gophish** – Navigates to the GoPhish installation folder.
- sudo** – Executes the command with administrator (root) privileges.
- ./gophish** – Starts the GoPhish phishing simulation server.

Security Weaknesses

1. Clicking Phishing Links (40%)

Weakness

- Employees could not identify phishing emails.

Risk

- Malware infection.
- Fake login pages.
- Credential theft.

2. Entering Login Credentials (20%)

Weakness

- Employees trusted fake websites.

Risk

- Account compromise.
- Unauthorized access.
- Data breaches.

3. Downloading Malicious Attachments

Weakness

- Lack of awareness about suspicious attachments.

Risk

- Malware installation.
- Ransomware infection.
- Remote access by attackers.

Recommended User Awareness Programs

Regular Security Awareness Training

Teach employees:

- Identify phishing emails.
- Verify sender addresses.
- Check suspicious links.
- Report suspicious emails.

Simulated Phishing Exercises

- Conduct monthly phishing campaigns.
- Measure employee improvement.
- Provide immediate feedback.

Password Security Training

- Use strong passwords.
- Never reuse passwords.
- Enable Multi-Factor Authentication.

Email Security Controls

- Email spam filtering.

- Attachment scanning.
- URL filtering.
- Anti-malware gateway.
- Email authentication:
 - SPF
 - DKIM
 - DMARC

Organizational Policies

- Mandatory cybersecurity awareness training.
- Password policy.
- Incident reporting procedure.
- Acceptable Use Policy.
- Least Privilege Principle.
- Regular security audits.

Conclusion

The report indicates a high level of susceptibility to phishing attacks. Continuous training, stronger email security controls, and well-defined organizational policies will greatly reduce successful social engineering attacks.

3. Dig DNS Assessment Report Analysis

Scenario

A Dig assessment shows that the DNS server allows a successful DNS Zone Transfer (AXFR).

The report exposes:

- Internal hostnames
- Mail servers

- DNS records

COMMAND: dig axfr example.com

EXPLANATION:

dig – Domain Information Groper tool used to query DNS servers.

axfr – Requests a DNS Zone Transfer (AXFR).

example.com – Specifies the target domain to test.

```

Applications ▾ Places ▾ Terminal ▾ Sat 17:45
root@kali: ~
root@kali:~# dig zonetransfer.me @nsztml.digi.ninja. -t axfr

; <<>> Dig 9.11.5-P4-1-Debian <<>> zonetransfer.me @nsztml.digi.ninja. -t axfr
;; global options: +cmd
zonetransfer.me. 7200 IN SOA nsztml.digi.ninja. robin.digi.ninja. 2017042001 172800 900 1209600 3600
zonetransfer.me. 300 IN HINFO "Casio fx-700G" "Windows XP"
zonetransfer.me. 301 IN TXT "google-site-verification=tyP28J73AUHA9fw2sHXMgcCC0I6XBmoVi04VlMewxA"
zonetransfer.me. 7200 IN MX 0 ASPMX.L.GOOGLE.COM.
zonetransfer.me. 7200 IN MX 10 ALT1.ASPMX.L.GOOGLE.COM.
zonetransfer.me. 7200 IN MX 10 ALT2.ASPMX.L.GOOGLE.COM.
zonetransfer.me. 7200 IN MX 20 ASPMX2.GOOGLEMAIL.COM.
zonetransfer.me. 7200 IN MX 20 ASPMX3.GOOGLEMAIL.COM.
zonetransfer.me. 7200 IN MX 20 ASPMX4.GOOGLEMAIL.COM.
zonetransfer.me. 7200 IN MX 20 ASPMX5.GOOGLEMAIL.COM.
zonetransfer.me. 7200 IN A 5.196.105.14
zonetransfer.me. 7200 IN NS nsztml.digi.ninja.
zonetransfer.me. 7200 IN NS nsztml2.digi.ninja.
sip.tcp.zonetransfer.me. 14000 IN SRV 0 0 5060 www.zonetransfer.me.
14.105.196.5.IN-ADDR.ARPA.zonetransfer.me. 7200 IN PTR www.zonetransfer.me.
asfdbauthdns.zonetransfer.me. 7900 IN AFSDB 1 asfdbbox.zonetransfer.me.
asfdbbox.zonetransfer.me. 7200 IN A 127.0.0.1
asfdbvolume.zonetransfer.me. 7800 IN AFSDB 1 asfdbbox.zonetransfer.me.
canberra-office.zonetransfer.me. 7200 IN A 202.14.81.230
cmdexec.zonetransfer.me. 300 IN TXT ";"
contact.zonetransfer.me. 2592000 IN TXT "Remember to call or email Pippa on +44 123 4567890 or pippa@zonetransfer.me when making DNS changes"
dc-office.zonetransfer.me. 7200 IN A 143.228.181.132
deadbeef.zonetransfer.me. 7201 IN AAAA dead:beaf::
dr.zonetransfer.me. 300 IN LOC 53 20 56.558 N 1 38 33.526 W 0.00m 1m 10000m 10m
DZC.zonetransfer.me. 7200 IN TXT "AbCdEfG"
email.zonetransfer.me. 2222 IN NAPTR 1 1 "P" "E2U+email" "" email.zonetransfer.me.zonetransfer.me.

```

Security Implications

Exposure of Internal Hostnames

Attackers learn:

- Internal server names.

- Domain structure.
- Network layout.

Exposure of Mail Servers

Attackers identify:

- Email servers.
- Mail exchange (MX) records.

This helps launch:

- Phishing attacks.
- Spam campaigns.
- Email spoofing.

Exposure of DNS Records

The attacker gains information about:

- Web servers.
- Database servers.
- VPN servers.
- Subdomains.

This greatly assists reconnaissance.

Possible Attacker Exploitation

An attacker may:

- Map the organization's network.
- Identify valuable servers.
- Launch targeted attacks.
- Discover hidden services.
- Perform phishing using mail server information.
- Exploit vulnerable systems.

Best Practices to Secure DNS Infrastructure

Disable Unauthorized Zone Transfers

Allow AXFR only for authorized secondary DNS servers.

Restrict DNS Access

Use firewalls and Access Control Lists (ACLs).

Enable DNSSEC

Protect DNS responses from tampering.

Keep DNS Software Updated

Apply security patches regularly.

Monitor DNS Logs

Detect unusual DNS activity.

Remove Unnecessary DNS Records

Avoid exposing internal systems.

Conclusion

Allowing unrestricted DNS Zone Transfers exposes valuable information that attackers can use for reconnaissance and targeted attacks. Restricting AXFR, implementing DNSSEC, maintaining updated DNS servers, and continuously monitoring DNS activity help secure the organization's DNS infrastructure.

Code of Conduct:

I Lavanya k(192565025) (Name / Reg No) certify that this submission is my original work and that I have

adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: